

FINAL PROJECT REPORT

Evaluating PostgreSQL Authentication Hardening Against Known-Credential Exploitation in a Containerized Stack

Submitted by

NAME: Ebefa Favour Epebiyerin

EMAIL: ebefafavour2015@gail.com

Course: CYBERSECURITY, AI & SECURITY+
CLASS: COHORT 2 - OPERATION SECURE CORE

INSTRUCTOR/FACILITATOR: MR JOSHUA & MR SADIQ

INSTITUTION: IHIFIX ACADEMY

PROGRAM: SCHOLARSHIP

GITHUB REPO:

https://github.com/favorebefa/Final-Project_postgresql-authentication-hardening.git

Submission Date: 10 September 2026

ABSTRACT

This project evaluates the extent to which PostgreSQL authentication hardening controls prevent unauthorized remote connections using a previously known credential in an authorized, local/containerized laboratory environment. The primary experiment used the Week 1 Docker PostgreSQL stack with PostgreSQL 15 (`postgres:15-alpine`). A before-and-after design established baseline authentication and network-access conditions, rotated the laboratory credential, retained SCRAM-SHA-256 authentication, restricted PostgreSQL host-based authentication through `pg_hba.conf`, reloaded the configuration, and tested permitted and rejected connection conditions. Principal evidence consisted of configuration screenshots, successful and failed authentication observations, active HBA-rule verification, source-address observations, a test matrix, and SHA-256 hashes for retained evidence. Baseline testing demonstrated that a previously known credential could authenticate remotely through the published PostgreSQL port. After credential rotation and HBA restriction, the old credential failed authentication while the authorized post-hardening path remained functional. A supplementary direct-LAN test demonstrated HBA source-address enforcement without Docker Desktop source-address translation affecting the observed client address. The findings support the hypothesis for the specific laboratory scenario. The main recommendation is to retain SCRAM-SHA-256 and apply narrowly scoped HBA rules alongside credential rotation and additional network, privilege, monitoring, and secrets-management controls. The principal limitation is that the experiment was local and controlled and therefore does not establish production-wide security effectiveness.

Executive Summary

The security problem investigated was the possibility that a previously known PostgreSQL credential could continue to provide remote access when the database service was reachable over a network. The project focused on whether authentication hardening could reduce this specific risk without breaking legitimate access. The investigation was deliberately constrained to an authorized classroom laboratory using learner-controlled systems and laboratory credentials.

The primary test environment was the Week 1 Docker stack. PostgreSQL 15 was exposed through the Windows host on TCP port 5432 and used SCRAM-SHA-256 for password authentication. Baseline inspection established that PostgreSQL listened on all interfaces and that a general host HBA rule permitted password authentication. A controlled remote connection from Kali Linux using the previously known laboratory credential succeeded. The PostgreSQL session reported a Docker bridge gateway address as the observed client address, an important networking observation that influenced how the HBA restriction was implemented.

Hardening consisted of rotating the database credential, confirming that SCRAM-SHA-256 remained active, restricting the HBA rule to the source address observed by PostgreSQL, reloading the configuration, and validating the resulting state. The authorized post-hardening connection using the new credential succeeded. The previously known credential was rejected with a password-authentication failure. A supplementary direct-LAN PostgreSQL test demonstrated that when PostgreSQL directly observed the Windows client's LAN address, a restrictive HBA rule could deny that source.

The evidence indicates that credential rotation directly invalidated the previously known credential, while HBA restrictions reduced the permitted source boundary. SCRAM-SHA-256 remained active throughout the hardening process and provided the authentication mechanism for the permitted connection. The combined controls materially reduced the investigated unauthorized-access condition, but the result should not be interpreted as proof of production security. Residual risk remains from network exposure, privilege concentration, secret-management practices, monitoring gaps, and the limitations of a small local experiment.

The recommended production direction is layered defense: maintain SCRAM-SHA-256, rotate credentials through controlled secret-management processes, restrict HBA rules to the narrowest justified source set, reduce unnecessary database exposure at the network layer, apply least privilege, enable appropriate TLS and authentication monitoring, and periodically retest the controls.

TABLE OF CONTENTS

Abstract

Executive Summary

List of Figures

Figure 1 — System Architecture of the Containerized PostgreSQL Test Environment

List of Tables

Abbreviations and Technical Terms

CHAPTER 1 — INTRODUCTION

CHAPTER 2 — BACKGROUND AND RELATED WORK

CHAPTER 3 — THREAT MODEL, RISK, AND CONTROL CONTEXT

CHAPTER 4 — METHODOLOGY AND ETHICAL SCOPE

CHAPTER 5 — TECHNICAL IMPLEMENTATION AND SYSTEM EXAMINATION

CHAPTER 6 — RESULTS AND EVIDENCE

CHAPTER 7 — ANALYSIS AND DISCUSSION

CHAPTER 8 — RISK AND CONTROL ASSESSMENT

CHAPTER 9 — RECOMMENDATIONS AND IMPROVEMENT PLAN

CHAPTER 10 — LIMITATIONS AND FUTURE WORK

CONCLUSION

DEDICATION

REFERENCES

Appendix A — Evidence Index

Appendix B — Test Matrix

Appendix C — Authentication Test Procedure

Appendix D — Hardened PostgreSQL Security Policy

Appendix E — AI Use and Verification Record

LIST OF FIGURES

1. Primary laboratory architecture
2. Before-and-after authentication flow
3. Layered PostgreSQL security controls
4. Baseline HBA configuration
5. Baseline listening configuration
6. Baseline published PostgreSQL port
7. Baseline remote authentication
8. SCRAM-SHA-256 verification
9. HBA restriction and reload
10. Active post-hardening HBA rule
11. Post-hardening authorized state
12. Direct-LAN source validation
13. Previously known credential rejection
14. HBA source-address denial

LIST OF TABLES

1. Project objectives
2. Control context
3. Technical environment
4. Test variables
5. Test sequence
6. Primary results
7. Risk/control assessment
8. Recommendations
9. Evidence index

10. Test matrix

ABBREVIATIONS AND TECHNICAL TERMS

TERM	MEANING
HBA	PostgreSQL Host-Based Authentication rules in <code>pg_hba.conf</code> .
LAN	Local Area Network.
NIST	National Institute of Standards and Technology.
SCRAM-SHA-256	Salted Challenge Response Authentication Mechanism using SHA-256.
TCP	Transmission Control Protocol.
TLS	Transport Layer Security.
Known credential	A credential valid in the controlled baseline; the actual secret is omitted.
Source address	The network address PostgreSQL observes for a connecting client.

CHAPTER 1 — INTRODUCTION

1.1 PROJECT CONTEXT

Database authentication is a security boundary between a network-reachable database service and the identities permitted to use it. PostgreSQL provides password authentication through configured authentication methods and applies connection rules through `pg_hba.conf`. In a containerized environment, the effective source address seen by PostgreSQL may differ from the address assigned to the original client because container networking and published ports can introduce translation.

This project examines that problem in a controlled classroom laboratory. It uses the Week 1 Docker PostgreSQL stack as the primary environment and focuses on authentication hardening rather than repeating the Week 1 vulnerability-scanning objective.

1.2 SECURITY PROBLEM

A previously known database credential may continue to authenticate remotely when PostgreSQL is network reachable and the HBA policy permits the connection. Credential rotation can invalidate the known secret, while source-based HBA restrictions can reduce the set of network origins from which authentication is accepted.

1.3 PROJECT AIM

The aim is to experimentally evaluate whether credential rotation, continued SCRAM-SHA-256 authentication, and restrictive PostgreSQL HBA rules reduce unauthorized remote access using a previously known credential while preserving the intended authorized access path.

1.4 RESEARCH QUESTION

To what extent do SCRAM-SHA-256 authentication and restrictive `pg_hba.conf` rules prevent unauthorized remote PostgreSQL connections using a previously known credential in a

1.5 OBJECTIVES

Objective	Success indicator
Establish a controlled baseline for remote authentication.	Baseline configuration and remote authentication documented.
Verify authentication and network exposure.	SCRAM, listening configuration, and published port observed.
Rotate the known credential while retaining SCRAM.	Old credential fails; new authorized credential succeeds.
Apply and validate restrictive HBA source rules.	Permitted source succeeds; excluded source is denied.
Assess controls and residual risk.	Evidence-linked analysis and recommendations produced.

1.6 HYPOTHESIS

H1: In the controlled laboratory environment, rotating the previously known PostgreSQL credential while retaining SCRAM-SHA-256 and applying a restrictive `pg_hba.conf` source rule will prevent the previously known credential from obtaining unauthorized remote access while preserving the intended authorized connection path.

Alternative explanation: a failed connection could result from network reachability, an incorrect HBA source rule, configuration reload failure, or another environmental condition. The methodology therefore distinguishes HBA denial from password rejection and includes configuration validation.

1.7 SCOPE AND EXCLUSIONS

- Authorized local/classroom systems only: Docker PostgreSQL, Windows host, and Kali Linux laboratory systems.
- Primary target: the Week 1 Docker PostgreSQL service.
- Supplementary direct-LAN PostgreSQL test used only to validate source-address/HBA behavior.
- No public or third-party systems, real accounts, password cracking, denial-of-service, persistence, exfiltration, or evasion testing.

- Actual authentication secrets and unnecessary network-identifying details are excluded from this report.

1.8 SIGNIFICANCE

The project demonstrates that authentication controls operate in layers. A strong password authentication mechanism does not by itself revoke a credential that has already been disclosed. Credential rotation changes credential state; HBA rules change the permitted source boundary; and configuration validation establishes that intended controls are active.

1.9 REPORT STRUCTURE

Chapters 2–3 establish the technical and security context. Chapter 4 documents research design, environment, procedure, evidence controls, and ethics. Chapter 5 describes implementation. Chapter 6 presents results. Chapters 7–10 interpret findings, assess risk, recommend improvements, and document limitations and future work. The conclusion answers the research question directly.

CHAPTER 2 — BACKGROUND AND RELATED WORK

2.1 POSTGRESQL CLIENT AUTHENTICATION

PostgreSQL separates connection acceptance from authentication policy. The `pg_hba.conf` file defines which database, user, client address, and authentication method apply to a connection. Matching rules are evaluated in order, making rule order and source-address accuracy security-relevant.

2.2 SCRAM-SHA-256

SCRAM-SHA-256 is a challenge-response password authentication mechanism supported by PostgreSQL. In this project it is treated as the authentication mechanism, not as a network-boundary control. The experiment therefore evaluates SCRAM together with credential rotation and HBA restrictions.

2.3 CREDENTIAL ROTATION

Credential rotation replaces a credential so that a previously known value is no longer valid. The key observable is the authentication outcome: the old laboratory credential must fail after rotation, while the authorized replacement credential must succeed when the HBA policy permits it.

2.4 HOST-BASED AUTHENTICATION RESTRICTIONS

HBA rules provide a source-aware access-control layer. A rule can restrict database, user, client address, and authentication method. A narrowly scoped source rule reduces the number of network origins from which a credential can be used, but it must match the source PostgreSQL actually observes.

2.5 CONTAINER NETWORKING

The primary Docker test demonstrated that a connection originating from the Kali host was observed inside PostgreSQL as the Docker bridge gateway address. A rule written only for the original Kali LAN address therefore did not match. This observation influenced the final primary HBA rule and was independently examined through a direct-LAN supplementary test.

2.6 LAYERED SECURITY

Credential rotation, SCRAM-SHA-256, HBA restrictions, network controls, least privilege, TLS, secrets management, and monitoring address different failure conditions. The experiment directly evaluates only the controls observable within its scope.

2.7 RELATED GUIDANCE

The project guide recommends authoritative standards, vendor documentation, and professional security guidance. NIST SP 800-115 provides a useful methodological reference for planning and conducting technical security tests; it is not used to classify this work as a formal penetration test.

CHAPTER 3 — THREAT MODEL, RISK, AND CONTROL CONTEXT

3.1 ASSETS

- PostgreSQL database service and authentication boundary.
- Database credentials and lifecycle.
- Database availability and authorized access path.
- Configuration integrity, especially `pg_hba.conf`.
- Evidence generated during the experiment.

3.2 THREAT ACTOR / FAILURE SOURCE

The modeled actor is an unauthorized party who possesses a previously known valid database credential and can reach the database service through the laboratory network path. The actor is a controlled test condition, not a real-world intrusion.

3.3 TRUST BOUNDARIES AND ATTACK SURFACE

The primary boundary is the Windows host's published PostgreSQL port into the Docker PostgreSQL service. A second boundary exists between the source address observed by PostgreSQL and the HBA rule that decides whether the connection may proceed.

3.4 SECURITY OBJECTIVES

OBJECTIVE	CONTROL RELEVANCE
Confidentiality	Prevent an unauthorized holder of an old credential from authenticating.
Integrity	Reduce unauthorized database access and modification opportunities.
Availability	Preserve the intended authorized connection after hardening.
Authenticity	Require successful authentication using the current credential.
Accountability	Retain traceable evidence of configuration and outcomes.

3.5 CONTROL CONTEXT

Control	Purpose	Boundary
Credential rotation	Invalidates previously known credential.	Does not prevent compromise of another credential.
SCRAM-SHA-256	Provides password authentication.	Does not restrict source by itself.
Restrictive HBA	Limits accepted sources and auth policy.	Depends on correct observed source.
Reload/verification	Activates and validates policy.	Does not provide monitoring.
Network controls	Can reduce reachability.	Not evaluated as a production firewall.

3.6 RESIDUAL RISK

Residual risk remains if the current credential is compromised, the database is unnecessarily exposed, privileged accounts are used broadly, secrets are stored insecurely, HBA rules are changed incorrectly, TLS is absent where required, or authentication events are not monitored.

CHAPTER 4 — METHODOLOGY AND ETHICAL SCOPE

4.1 RESEARCH DESIGN

A controlled before-and-after experimental design was used. Baseline conditions were observed first. Hardening changes were then applied, reloaded, and validated through positive and negative cases. A supplementary direct-LAN test isolated source-address behavior.

4.2 TECHNICAL ENVIRONMENT

COMPONENT	CONFIGURATION / VERSION
Host	Windows 10 laboratory workstation
Container runtime	Docker Desktop 4.83.0 / Docker Engine 29.6.2
Primary database	PostgreSQL 15, `postgres:15-alpine`
Primary container	`medusa-postgres`
Docker network	Bridge network, laboratory `172.18.0.0/16` range
Database port	TCP 5432
Primary client	Kali Linux laboratory VM
Supplementary database	PostgreSQL 18.4 on Kali
Windows client	Official PostgreSQL 18.6 `psql` binary
Evidence integrity	SHA-256 hashes for 15 retained files

4.3 TOOLS

- Docker CLI for container/network inspection.
- PostgreSQL `psql` for authentication and SQL validation.
- PowerShell/Test-NetConnection for direct-LAN connectivity.
- Kali PostgreSQL for supplementary validation.
- SHA-256 hashing for retained evidence.

4.4 VARIABLES

VARIABLE	TYPE	OPERATIONALIZATION
Credential state	Independent	Previously known vs rotated laboratory credential.
HBA source rule	Independent	Broad host rule vs restricted source.
Authentication method	Controlled	SCRAM-SHA-256 retained.
Client source	Observed	Address PostgreSQL sees after network translation.
Authentication outcome	Dependent	Success, password rejection, or HBA rejection.

4.5 BASELINE PROCEDURE

Baseline inspection established HBA host rules, listening configuration, published port, and authentication method. A remote connection from Kali to the Windows host's published PostgreSQL port was made using the previously known laboratory credential. A session query recorded user, database, and observed client source.

4.6 HARDENING PROCEDURE

- Rotate the laboratory credential without retaining the secret in submission artifacts.
- Confirm SCRAM-SHA-256 remains active.
- Apply an HBA source rule matching the address PostgreSQL observes.
- Reload PostgreSQL configuration.
- Verify active HBA rules and configuration status.
- Test the new authorized credential.
- Test the previously known credential and record failure.
- Perform supplementary direct-LAN source/HBA validation.

4.7 EXPECTED RESULTS

CONDITION	EXPECTED RESULT
Baseline known credential	Remote authentication succeeds.
Old credential after rotation	Authentication fails.
New authorized credential	Authentication succeeds when HBA permits.
Excluded source	HBA rejects connection.
Verifier after hardening	SCRAM-SHA-256 remains active.

4.8 EVIDENCE COLLECTION AND INTEGRITY

Evidence was collected during testing and organized into BEFORE, AFTER, and Network Validation categories. Fifteen retained evidence files were hashed using SHA-256. A screenshot containing the actual temporary laboratory credential was intentionally excluded from the final evidence package.

4.9 ETHICAL AND SAFETY CONTROLS

- All testing remained inside the authorized local/classroom environment.
- No public or third-party systems were targeted.
- No password cracking, brute force, denial-of-service, persistence, evasion, or exfiltration was performed.
- Temporary Docker resources created for network testing were removed.
- Authentication secrets were excluded from the final report and repository.

4.10 METHOD LIMITATIONS

The experiment uses a small local environment and controlled credential conditions. It does not measure long-term operations, enterprise identity integration, password-cracking resistance, firewall effectiveness, or production monitoring. Docker Desktop networking also changes the source address visible to PostgreSQL.

CHAPTER 5 — TECHNICAL IMPLEMENTATION AND SYSTEM EXAMINATION

5.1 PRIMARY ARCHITECTURE

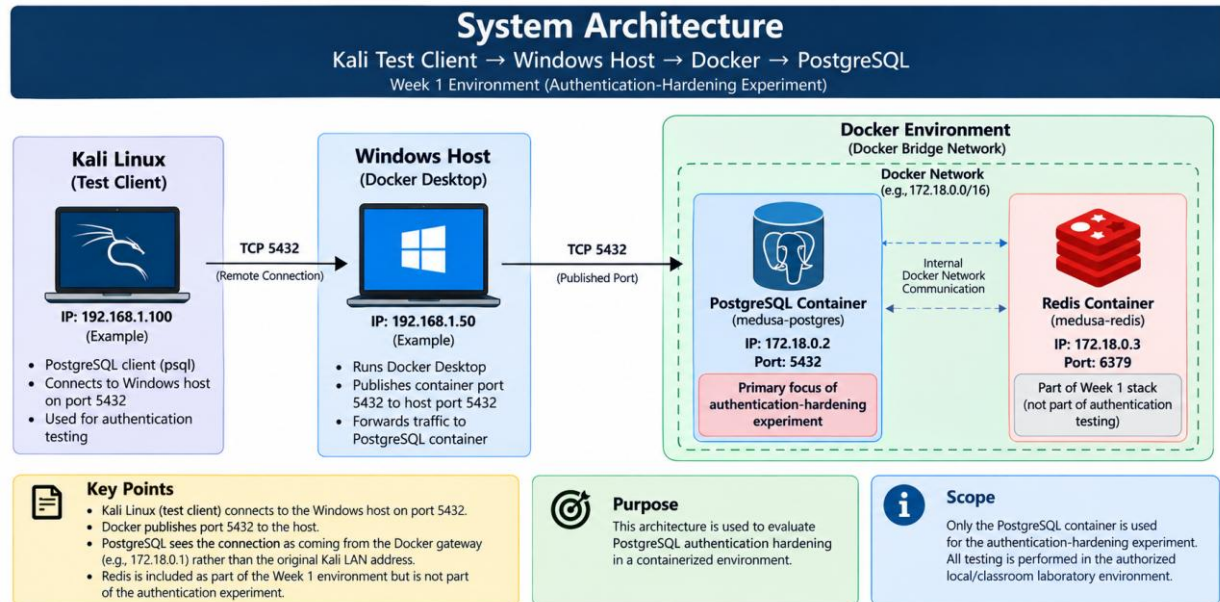


Figure 1 — System Architecture of the Containerized PostgreSQL Test Environment

The primary path consisted of Kali Linux as test client, the Windows host as Docker Desktop host, the Docker-published TCP 5432 endpoint, and PostgreSQL 15. The PostgreSQL container used a bridge network. PostgreSQL observed the Docker bridge gateway as the source of the published-port connection.

LAYER	COMPONENT	SECURITY RELEVANCE
Client	Kali Linux	Authorized remote authentication test source.
Host	Windows Docker host	Publishes PostgreSQL port.
Container network	Docker bridge	Affects source-address visibility.
Database	PostgreSQL 15	Performs authentication/HBA evaluation.
Policy	<code>'pg_hba.conf'</code>	Controls source/database/user/authentication matching.

Figure 1. Primary laboratory architecture

Source: project evidence and controlled laboratory testing.

5.2 BASELINE CONFIGURATION

The baseline HBA inspection showed a general host rule using SCRAM-SHA-256 for non-local host connections. PostgreSQL listened on all interfaces, and Docker published TCP 5432. Baseline verifier evidence confirmed SCRAM-SHA-256.

5.3 BASELINE AUTHENTICATION

The remote baseline test from Kali successfully authenticated using the previously known laboratory credential. PostgreSQL reported the Docker bridge gateway as the observed client source. This became a key input to HBA hardening.

5.4 CREDENTIAL ROTATION

The PostgreSQL role credential was changed to a new laboratory value. The actual value is intentionally omitted. The verifier remained SCRAM-SHA-256.

5.5 HBA Restriction

An initial HBA restriction based on the original Kali LAN address did not match the source PostgreSQL observed through Docker and produced an HBA rejection. The source observation was used to correct the rule rather than misclassifying the denial as a credential failure.

5.6 Supplementary Direct-LAN Validation

PostgreSQL running directly on Kali was configured to listen on its LAN address. A Windows client connected directly to Kali, and PostgreSQL observed the Windows client's LAN address. A restrictive HBA rule then excluded that source and produced an HBA denial.

5.7 Reproducibility

The project materials contain the README, test procedure, evidence index, test matrix, security policy, analysis, and configuration. Reproduction should use a new laboratory credential.

CHAPTER 6 — RESULTS AND EVIDENCE

6.1 BASELINE RESULTS

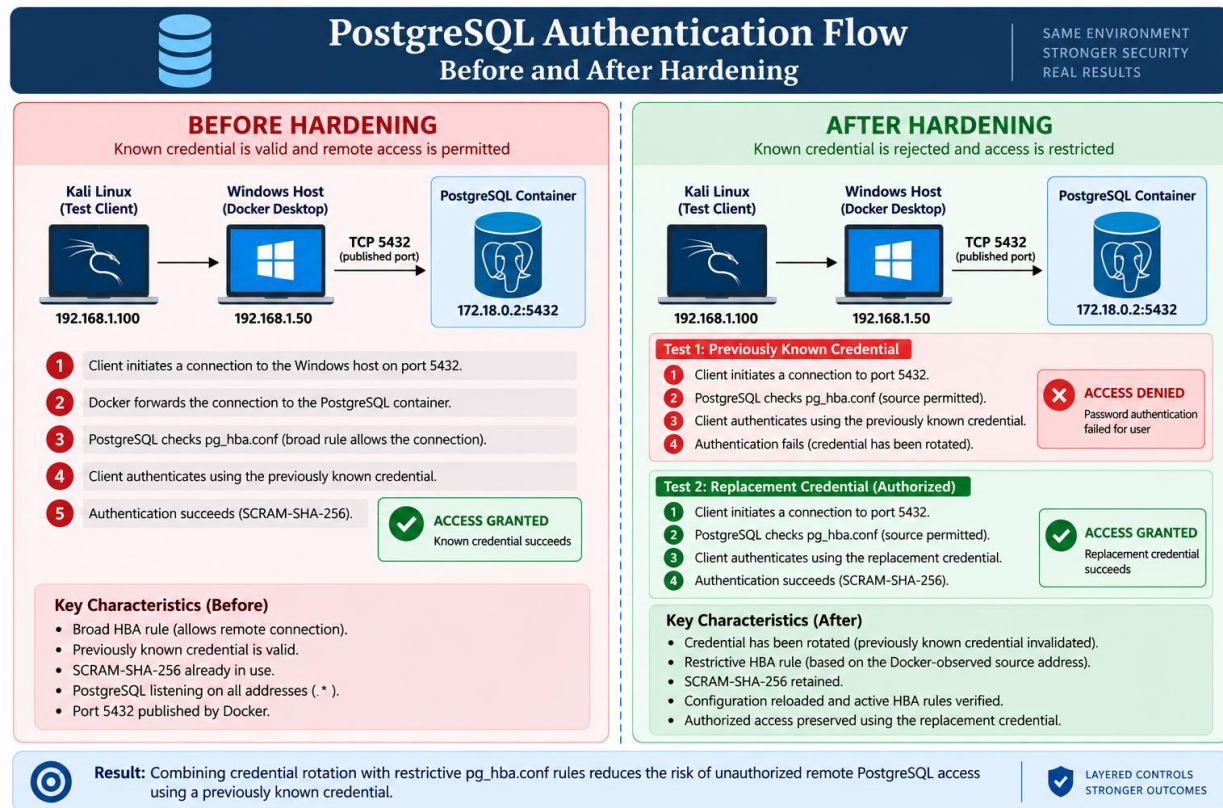


Figure 2 — PostgreSQL Authentication Flow: Before and After Hardening

TEST	OBSERVED RESULT	EVIDENCE
T-001 Baseline remote authentication	Previously known credential successfully authenticated remotely.	E-004, E-005
T-002 Baseline HBA	General host SCRAM rule observed.	E-001
T-003 Listening configuration	PostgreSQL listened on all interfaces.	E-002
T-004 Published port	TCP 5432 published by Docker.	E-003
T-005 Authentication verifier	SCRAM-SHA-256 active.	E-004

6.2 HARDENING RESULTS

TEST	OBSERVED RESULT	EVIDENCE
T-006 Credential/verifier	Credential rotated; SCRAM retained.	E-006
T-007 Reload	Reload succeeded.	E-008
T-008 HBA restriction	Restricted source rule applied.	E-009
T-009 Active HBA	Intended rule active with no error.	E-010
T-010 Authorized state	Authorized connection remained functional.	E-011
T-011 Final HBA	Final rule remained active.	E-012

6.3 NEGATIVE AND SUPPLEMENTARY RESULTS

TEST	OBSERVED RESULT	EVIDENCE
T-012 Source validation	Windows LAN source observed directly by Kali PostgreSQL.	E-013
T-013 Old credential	Previously known credential rejected.	E-014
T-014 HBA denial	Excluded source rejected by HBA.	E-015

6.4 PRIMARY FINDING

Baseline evidence showed successful remote authentication using the previously known credential. After credential rotation, that credential failed authentication while the intended authorized connection remained functional. This supports the finding that credential rotation materially reduced the specific known-credential access condition.

6.5 NETWORK OBSERVATION

The Docker path caused PostgreSQL to observe the Docker bridge gateway as the client source. Therefore, HBA policy must be designed around the address visible at the enforcement point.

6.6 EVIDENCE HANDLING

The final submission omits the screenshot containing the actual temporary credential. The retained evidence set contains 15 approved files and a SHA-256 hash manifest.

CHAPTER 7 — ANALYSIS AND DISCUSSION

7.1 BASELINE INTERPRETATION

Observation: the previously known credential authenticated remotely. Interpretation: the baseline combined network reachability, a permissive host HBA rule, and a valid credential. Inference: possession of the known credential was sufficient to cross the database authentication boundary in the baseline scenario.

7.2 CREDENTIAL ROTATION

Observation: the previously known credential produced a password-authentication failure after rotation. Interpretation: the old credential was no longer valid. Inference: rotation was effective against the specific known-credential condition. This does not prove resistance to compromise of the replacement credential.

7.3 SCRAM-SHA-256

Observation: SCRAM-SHA-256 remained active before and after hardening. Interpretation: hardening did not require weakening the authentication mechanism. Inference: SCRAM provided the password-authentication layer while rotation and HBA addressed different access conditions.

7.4 HBA RESTRICTION

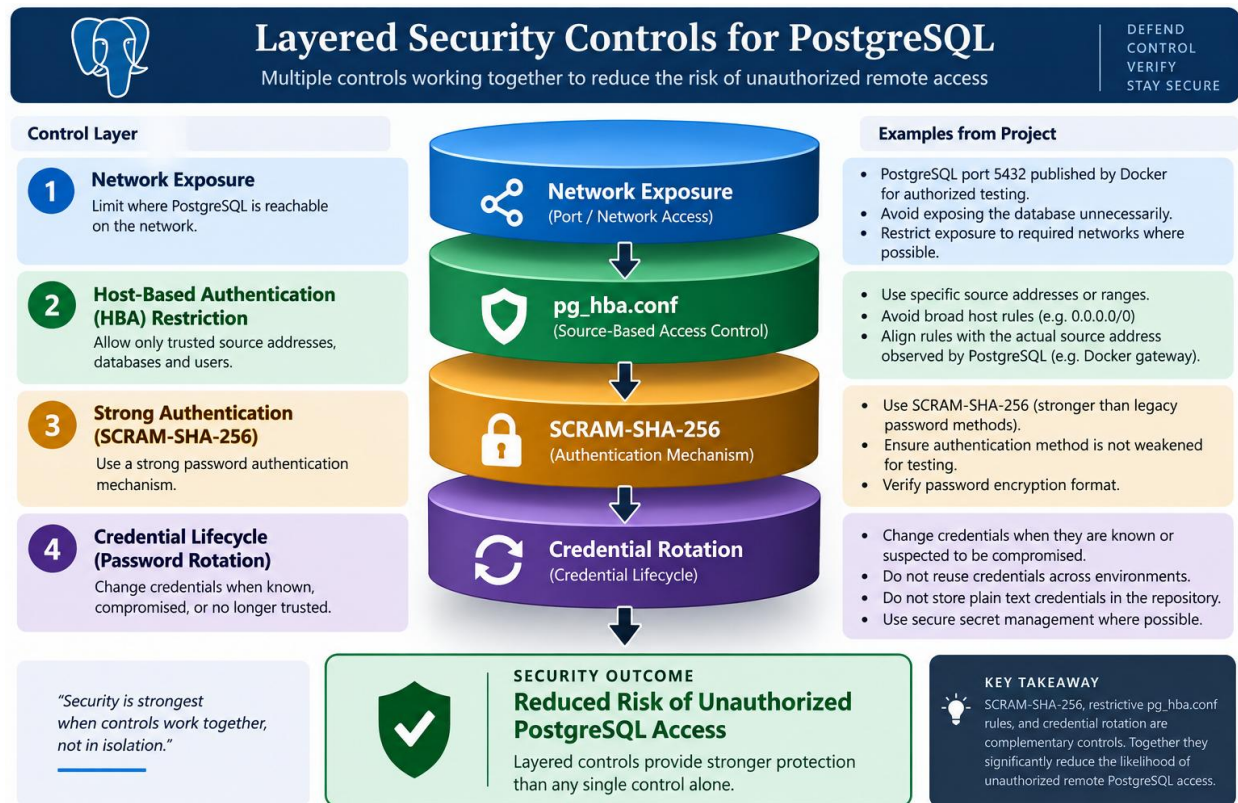


Figure 3 — Layered Security Controls for PostgreSQL

Observation: an HBA rule that did not match the observed source caused denial; a rule matching the permitted source allowed the authorized path. Interpretation: source restriction is effective when the source address is correctly understood. Inference: source-address translation is a material implementation consideration.

7.5 HYPOTHESIS ASSESSMENT

The hypothesis is supported for the tested laboratory condition. The evidence shows that the combined hardening state prevented the previously known credential from authenticating while preserving the intended authorized connection path.

7.6 ALTERNATIVE EXPLANATIONS

- HBA mismatch rather than password failure: distinguished by different PostgreSQL error conditions.
- Reload failure: addressed by explicit reload and active-rule verification.
- Network failure: addressed by successful authorized connections and connectivity validation.
- Docker source translation: directly observed and examined with supplementary testing.

7.7 WHAT THE EVIDENCE DOES NOT PROVE

- It does not prove resistance to all credential attacks.
- It does not prove the new credential cannot be compromised.
- It does not establish enterprise firewall/segmentation effectiveness.
- It does not establish long-term monitoring or incident-response effectiveness.
- It does not prove production security across other deployment architectures.

7.8 Discussion

The findings support a defense-in-depth interpretation: authentication strength, credential lifecycle, and network access control address different failure conditions. The experiment also demonstrates why observations must be separated from recommendations. Network segmentation, least privilege, TLS, and monitoring are risk-based improvements, not experimental results proven by this study.

CHAPTER 8 — RISK AND CONTROL ASSESSMENT

FINDING	AFFECTED ASSET/PROCESSES	SECURITY CONSEQUENCE	EVIDENCE	PRIORITY
Known credential authenticated at baseline.	PostgreSQL authentication	Unauthorized holder could authenticate through reachable service.	E-004,E-005	High
Old credential rejected after rotation.	Credential lifecycle	Previously known credential no longer authenticated.	E-014	High
HBA source restriction enforced.	Database network access	Excluded source could not proceed.	E-015	High
Docker source translation affected HBA matching.	Container networking	Incorrect source assumptions can cause unsafe or broken policy.	E-001,E-013,E-015	Medium
Database remained network published.	Network exposure	Authentication remains an exposed boundary.	E-003,E-007	Medium
Privileged role used for testing.	Privilege boundary	Compromise would have broad impact in a comparable deployment.	Configuration context	Medium

Priorities are qualitative. No precise quantitative risk score is claimed.

CHAPTER 9 — RECOMMENDATIONS AND IMPROVEMENT PLAN

Recommendation	Rationale	Priority	Owner	Validation
Maintain SCRAM-SHA-256.	Retained successfully during hardening.	High	Database administrator / security	Verifier and auth test
Implement controlled credential rotation.	Rotation invalidated the known credential.	High	Database/platform team	Old/new authentication tests
Restrict HBA to the narrowest justified source.	Source exclusion was demonstrably enforced.	High	Database administrator	Active rule and denied-source test
Reduce network exposure with firewalling/segmentation.	HBA is a database-layer control.	High	Network/platform team	Connectivity and firewall validation
Avoid routine use of highly privileged accounts.	Limits impact of credential compromise.	High	Database administrator	Role/privilege review
Enable appropriate TLS and authentication monitoring.	Adds confidentiality and detection layers.	Medium	Platform/SOC team	TLS and monitoring validation
Periodically retest authentication/HBA.	Detects configuration drift.	Medium	Security/platform team	Scheduled validation results

9.1 IMPLEMENTATION SEQUENCE

Phase 1: retain SCRAM-SHA-256, credential rotation, and restrictive HBA. Phase 2: reduce network exposure and privileged-account use. Phase 3: add monitoring, TLS validation, centralized secret management, and periodic control testing.

CHAPTER 10 — LIMITATIONS AND FUTURE WORK

10.1 LIMITATIONS

- Local classroom environment rather than production.
- Small, controlled credential scenario.
- Docker Desktop source-address translation may differ from other runtimes.
- No enterprise firewall, cloud security group, or Kubernetes evaluation.
- No long-term credential lifecycle, monitoring, revocation, or incident-response measurement.
- Only authentication/HBA conditions within the research question were tested.

10.2 FUTURE WORK

- Evaluate the control model with explicit network segmentation and firewall rules.
- Compare Docker Desktop with Linux-native container networking.
- Test least-privilege database roles.
- Evaluate TLS configuration and certificate lifecycle.
- Measure authentication-event logging and alerting.
- Test automated credential rotation with secrets management.
- Extend testing over time to evaluate configuration drift.

10.3 NEXT-STAGE CONTRIBUTION

The evidence base provides a controlled baseline, documented hardening sequence, test matrix, evidence identifiers, and clear separation between primary and supplementary experiments for future controlled exercises.

Conclusion

The research question asked whether SCRAM-SHA-256 authentication and restrictive `pg_hba.conf` rules prevent unauthorized remote PostgreSQL connections using a previously known credential in a containerized environment.

Within the tested laboratory environment, the controls were effective against the specific known-credential condition investigated. Baseline evidence showed that the previously known credential could authenticate remotely through the published PostgreSQL service. After credential rotation, that credential failed authentication, while the intended authorized connection using the rotated credential remained functional. SCRAM-SHA-256 remained active. HBA source restrictions also demonstrated effective denial when the observed source did not match the permitted policy.

The hypothesis is therefore supported for the experimental condition. The strongest evidence is the before-and-after authentication outcome, the active SCRAM verifier, the active restrictive HBA rule, and the supplementary direct-LAN HBA denial. The principal security implication is that authentication hardening should be treated as layered control: credential rotation addresses compromised or previously disclosed credentials, SCRAM-SHA-256 provides password authentication, and HBA rules reduce the permitted network source boundary.

The conclusion does not establish production-wide security. Production deployments should combine the demonstrated controls with network segmentation, least privilege, secure secrets management, TLS, authentication monitoring, and periodic validation.

DEDICATION

I want to sincerely dedicate this project work to God Almighty and to everyone who made it possible for me to be part of this Scholarship program, Especially the “YOUTH ALIVE FELLOWSHIP KUBWA”, and to the Organization “IHIFIX ACADEMY and to our Instructors Mr. Joshua Oladele and Mr. Sadiq Adam Ismail”, Secondly, I want to thank my parent Mr. and Mrs. Ebefa Perekeme for the support, and lastly to thank, one of the most important person in my life Mr. Cyril Ogah for the moral support and finances, may God Bless you all.

REFERENCES

1. Center for Internet Security. (n.d.). CIS Benchmarks. Center for Internet Security.
2. Docker. (n.d.). Bridge network driver. Docker Documentation.
3. Docker. (n.d.). Networking overview. Docker Documentation.
4. National Institute of Standards and Technology. (2008). Technical guide to information security testing and assessment (NIST SP 800-115).
5. National Institute of Standards and Technology. (2025). Digital identity guidelines: Authentication and lifecycle management (NIST SP 800-63B).
6. OWASP Foundation. (n.d.). Authentication Cheat Sheet. OWASP.
7. OWASP Foundation. (n.d.). Network Segmentation Cheat Sheet. OWASP.
8. PostgreSQL Global Development Group. (n.d.). Authentication methods. PostgreSQL Documentation.
9. PostgreSQL Global Development Group. (n.d.). Client authentication. PostgreSQL Documentation.
10. PostgreSQL Global Development Group. (n.d.). Database access privileges. PostgreSQL Documentation.
11. PostgreSQL Global Development Group. (n.d.). Database roles. PostgreSQL Documentation.
12. PostgreSQL Global Development Group. (n.d.). The `pg_hba.conf` file. PostgreSQL Documentation.
13. PostgreSQL Global Development Group. (n.d.). Secure TCP/IP connections with SSL. PostgreSQL Documentation.

Appendix A — Evidence Index

The retained evidence package contains 15 evidence items. The credential-containing screenshot is intentionally excluded from the final submission.

ID	FILE	TEST	DESCRIPTION	REDACTION
E-001	BEFORE/Current_PostgreSQL_HBA_Configuration.png	T-002	Baseline HBA configuration.	Controlled/redacted
E-002	BEFORE/Listen_Addresses.png	T-003	Baseline listening configuration.	Controlled/redacted
E-003	BEFORE/PostgreSQL_Expose_Port5432.png	T-004	Published PostgreSQL port.	Controlled/redacted
E-004	BEFORE/Valid_Baseline_Postgresql.png	T-001/T-005	Baseline authentication/verifier evidence.	Controlled/redacted
E-005	BEFORE/Remote_Access_Evidence.png	T-001	Successful baseline remote access.	Controlled/redacted
E-006	AFTER/Password_Format_Check.png	T-006	Post-hardening verifier check.	Controlled/redacted
E-007	AFTER/Postgres_Port.png	T-004	Post-hardening port state.	Controlled/redacted
E-008	AFTER/pg_reload_conf.png	T-007	Configuration reload.	Controlled/redacted
E-009	AFTER/HBA_Restriction_Rule_Set.png	T-008	HBA restriction applied.	Controlled/redacted
E-010	AFTER/Active_HBA_Rule.png	T-009	Active HBA verification.	Controlled/redacted
E-011	AFTER/Current_State.png	T-010	Authorized post-hardening state.	Controlled/redacted
E-012	AFTER/Active_HBA_Rule_2.png	T-011	Final HBA verification.	Controlled/redacted
E-013	Network Validation/Windows_to_Kali_Source_IP.png	T-012	Direct-LAN source validation.	Controlled/redacted
E-014	Network Validation/Windows_to_Kali_Old_Password_Rejected.png	T-013	Previously known credential rejected.	Controlled/redacted
E-015	Network Validation/Windows_to_Kali_HBA_Denied.png	T-014	HBA source-address denial.	Controlled/redacted

SHA-256 hashes for the 15 retained evidence files are maintained in `Evidence/evidence-hashes.txt`.

APPENDIX B — TEST MATRIX

TEST	CONDITION	EXPECTED	OBSERVED	EVIDENCE	INTERPRETATION
T-001	Baseline known credential	Success	Succeeded	E-004,E-005	Known credential was remotely usable.
T-002	Baseline HBA	Host rule identified	General host SCRAM rule	E-001	Baseline source restriction was broad.
T-003	Listen addresses	Network reachable if published	`*`	E-002	Network connections accepted subject to HBA.
T-004	Port mapping	5432 published	Published	E-003,E-007	Service was reachable.
T-005	Verifier	SCRAM active	SCRAM active	E-004	Authentication method retained.
T-006	Credential rotation	Old invalid; SCRAM retained	SCRAM retained	E-006	Lifecycle changed without weakening auth.
T-007	Reload	Reload succeeds	Succeeded	E-008	HBA changes activated.
T-008	HBA restriction	Source constrained	Applied	E-009	Boundary narrowed.
T-009	Active HBA	Rule active	Active/no error	E-010	Policy loaded correctly.
T-010	New authorized credential	Success	Succeeded	E-011	Intended access preserved.
T-011	Final HBA	Final rule active	Active	E-012	Final state consistent.
T-012	Direct-LAN source	Actual source visible	Observed	E-013	Source semantics validated.
T-013	Old credential after rotation	Failure	Password authentication failed	E-014	Old credential invalid.
T-014	Excluded source	HBA denial	HBA entry not found	E-015	Source restriction enforced.

Appendix C — Authentication Test Procedure

1. Inspect the PostgreSQL container and confirm version, health, network, and published port.
2. Inspect HBA rules and record the active host rule.
3. Confirm `'listen_addresses'` and SCRAM-SHA-256 verifier state.
4. Perform authorized baseline remote authentication and record observed client source.
5. Rotate the laboratory credential without recording the secret in report artifacts.
6. Confirm SCRAM-SHA-256 remains active.
7. Apply an HBA source rule based on the source PostgreSQL actually observes.
8. Reload PostgreSQL and verify the active rule has no error.
9. Authenticate using the new authorized credential.
10. Attempt authentication with the previously known credential and record rejection.
11. Perform supplementary direct-LAN source and HBA denial tests.
12. Restore the intended final laboratory configuration and preserve evidence hashes.

Reproduction must use authorized laboratory systems and newly generated laboratory credentials.

Appendix D — Hardened PostgreSQL Security Policy

The policy is to retain SCRAM-SHA-256, rotate credentials when a previously known credential must be invalidated, restrict HBA source addresses to the narrowest justified range, reload and verify configuration changes, and test both permitted and denied conditions.

POLICY AREA	REQUIRED STATE
Password authentication	SCRAM-SHA-256
Credential lifecycle	Rotate previously known/compromised laboratory credentials
HBA source scope	Narrowest justified source address/range
Configuration validation	Reload and inspect active HBA rules
Positive validation	Authorized current credential succeeds
Negative validation	Old credential fails; excluded source is denied
Sensitive data	No passwords, keys, tokens, or unnecessary private data in submission

Appendix E — AI Use and Verification Record

AI assistance was used as a review, documentation, structuring, and analysis aid. AI-generated suggestions were not treated as evidence. Technical claims were checked against observed PostgreSQL output, Docker behavior, project files, and controlled tests.

AI-ASSISTED ACTIVITY	VERIFICATION	OUTCOME
Report structure and guide alignment	Compared with uploaded final project guide.	Report organized into required hybrid format.
PostgreSQL/HBA interpretation	Checked against HBA rules, authentication outcomes, and reload state.	HBA denial separated from password rejection.
Docker source-address interpretation	Checked with <code>'inet_client_addr()'</code> and direct-LAN test.	Source translation documented.
Evidence organization	Checked filenames, test IDs, and SHA-256 manifest.	15 retained items mapped to tests.
Recommendations	Compared with observed control gaps.	Recommendations framed as risk improvements.

Appendix F — Reproducibility and Safety Boundaries

The project README and test procedure provide exact setup logic and test order. Reproduction should use a newly generated laboratory credential rather than any credential used during the study.

- Prerequisites: Docker Desktop/Linux containers, PostgreSQL client, authorized test client, controlled network.
- Test order: baseline → rotation → SCRAM verification → HBA restriction → reload → authorized validation → old credential rejection → supplementary validation.
- Evidence locations: `Evidence/BEFORE/`, `Evidence/AFTER/`, `Evidence/Network Validation/`.
- Verify SHA-256 hashes for retained evidence where appropriate.
- Remain inside the authorized environment; do not test public systems or real credentials.
- Do not place passwords, keys, tokens, `.env` files, or unnecessary private/network information in submission artifacts.